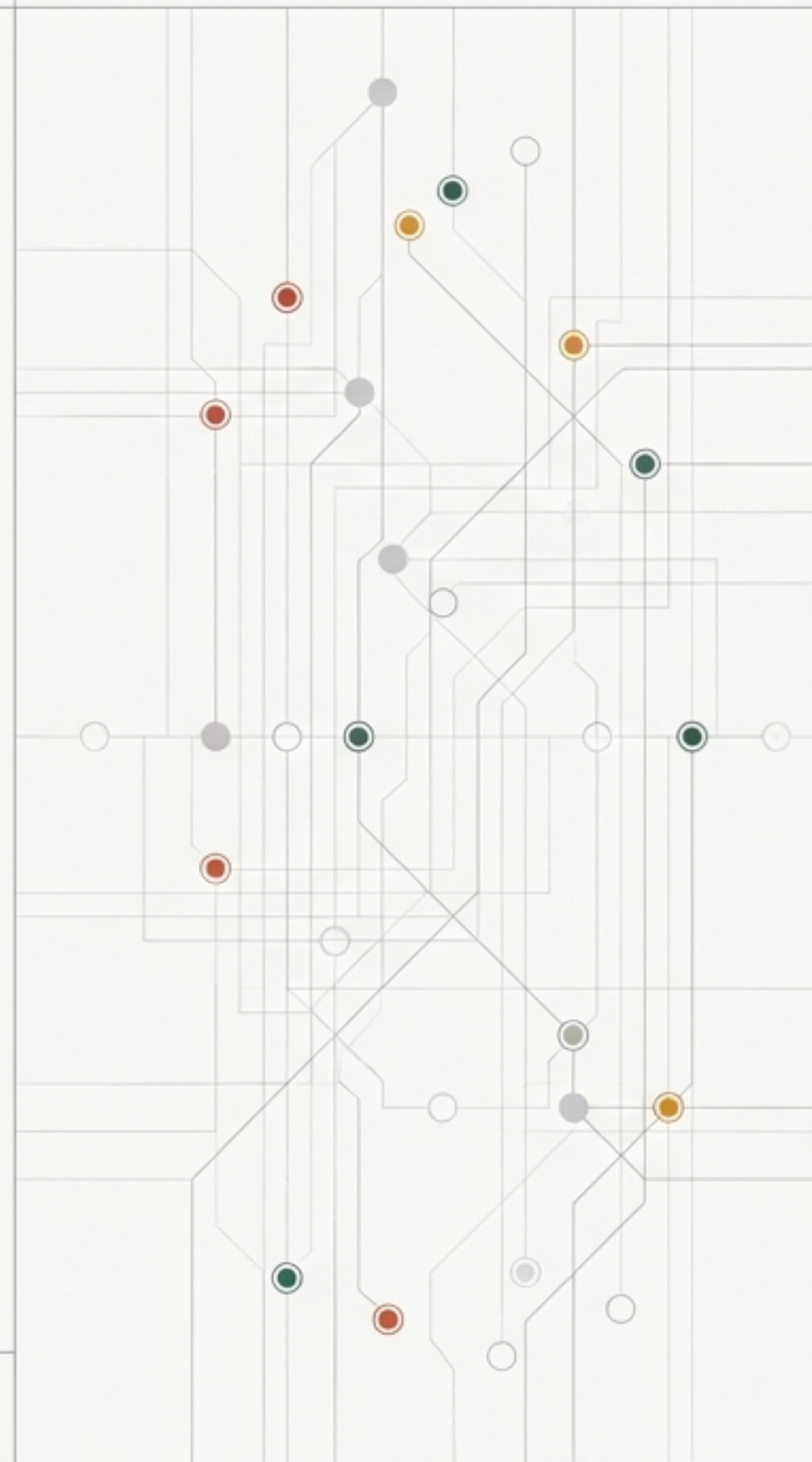


Privacy Classification of HTTP Request Metadata

Compliance Strategy & Technical
Implementation for SGraph Send

CONFIDENTIAL RESEARCH BRIEF | BASED ON UK GDPR, CCPA & EDPB GUIDELINES (2025)



Executive Summary: The Strategic Compliance Framework



The Regulatory Verdict

IP addresses and raw User-Agents must be treated as Personal Data (PII) based on the CJEU Breyer ruling and CCPA mandates.



The Solution

A 'Three-Tier' storage classification system separates safe data from toxic data, ensuring granular control over retention.



The Mechanism

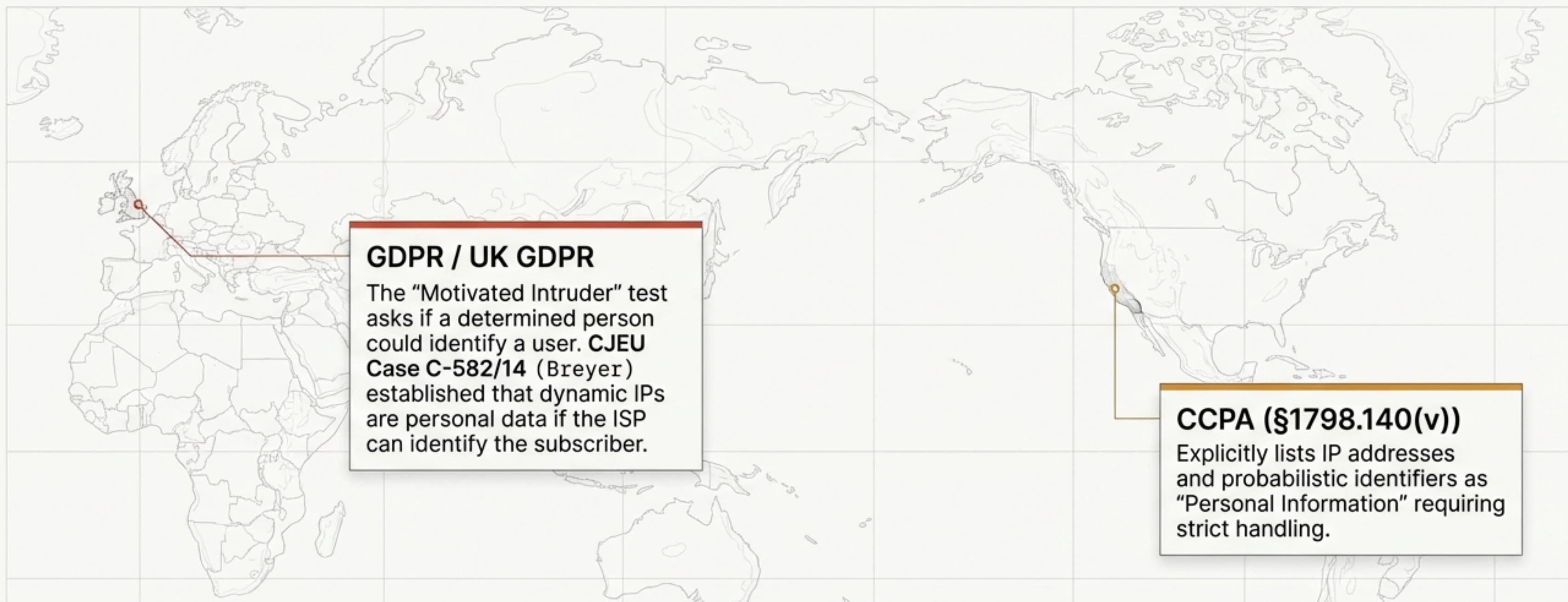
Implementation of HMAC-SHA256 hashing with daily rotating salts. Salts are destroyed every 24 hours to render re-identification mathematically impossible.



The Outcome

Preserves essential analytics (abuse detection, volume, country stats) while achieving 'effective anonymisation' per ICO standards.

The Regulatory Landscape Mandates Strict Metadata Control



GDPR / UK GDPR

The "Motivated Intruder" test asks if a determined person could identify a user. **CJEU Case C-582/14 (Breyer)** established that dynamic IPs are personal data if the ISP can identify the subscriber.

CCPA (§1798.140(v))

Explicitly lists IP addresses and probabilistic identifiers as "Personal Information" requiring strict handling.



Operational Assumption: Because operators rarely know at collection time if identification is feasible, we must treat all IP addresses as Personal Data.

Field Classification Heatmap

RED (PII - Stop/Transform)			
IP Address	Referer	Postal Code	Lat /Long Coordinates
Must be Hashed or Destroyed.			

AMBER (Quasi-Identifier - Caution)		
User-Agent String	City (<50k pop)	ASN (Small Corporate)
Requires Normalisation or Thresholding.		

GREEN (Safe - Store)				
Timestamp (Hourly)	Country	TLS Version	VPN Flag	Transfer Direction
Safe to Store in Plaintext.				

The Anonymisation Boundary: Why Simple Hashing Fails

Pseudonymisation (GDPR Art 4(5))

Data can still be attributed to a user (e.g., via a key). GDPR still applies.

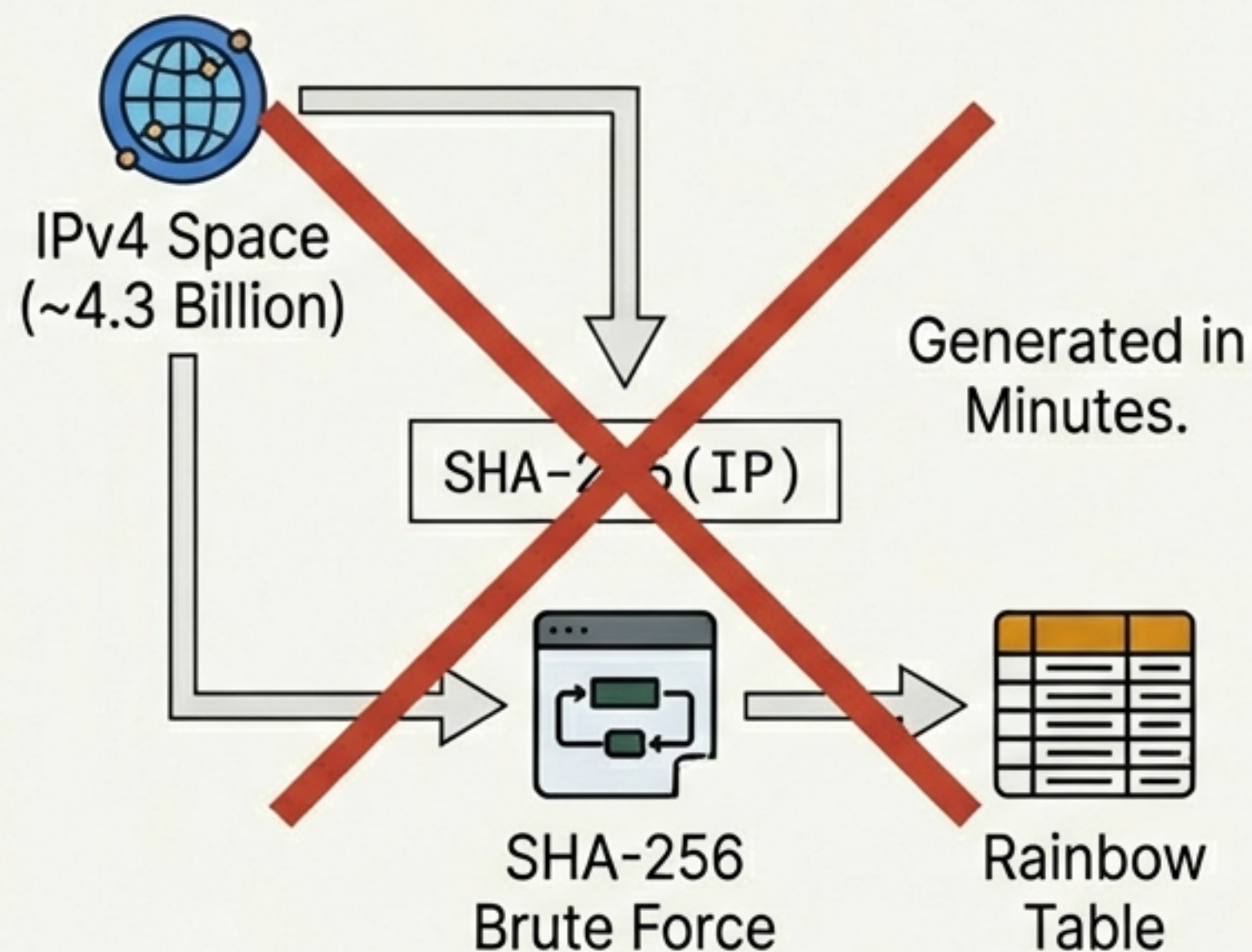
Anonymisation (Recital 26)

Identification is reasonably impossible. GDPR does not apply.

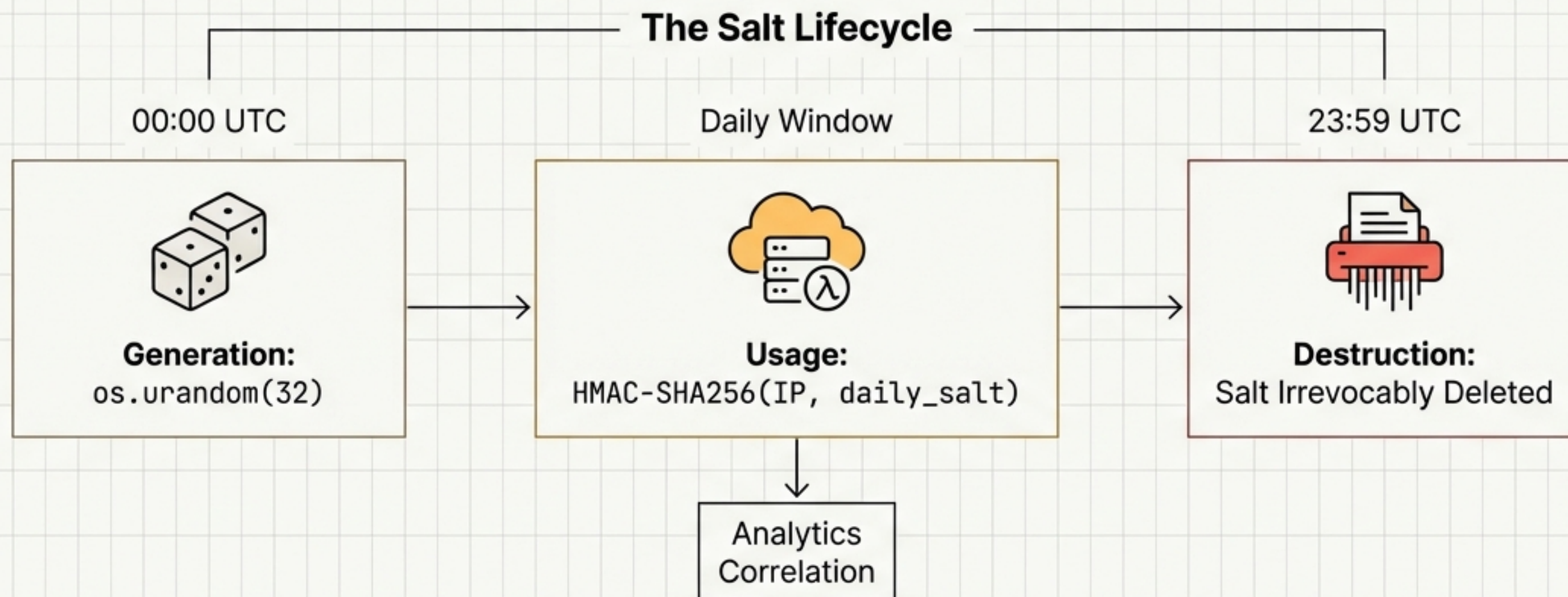
Regulatory Stance: EDPB Guidelines 01/2025

State simple hashing is merely a safeguard, not an exemption.

The Mathematical Problem



The Solution: HMAC-SHA256 with Ephemeral Rotating Salts



The Privacy Guarantee

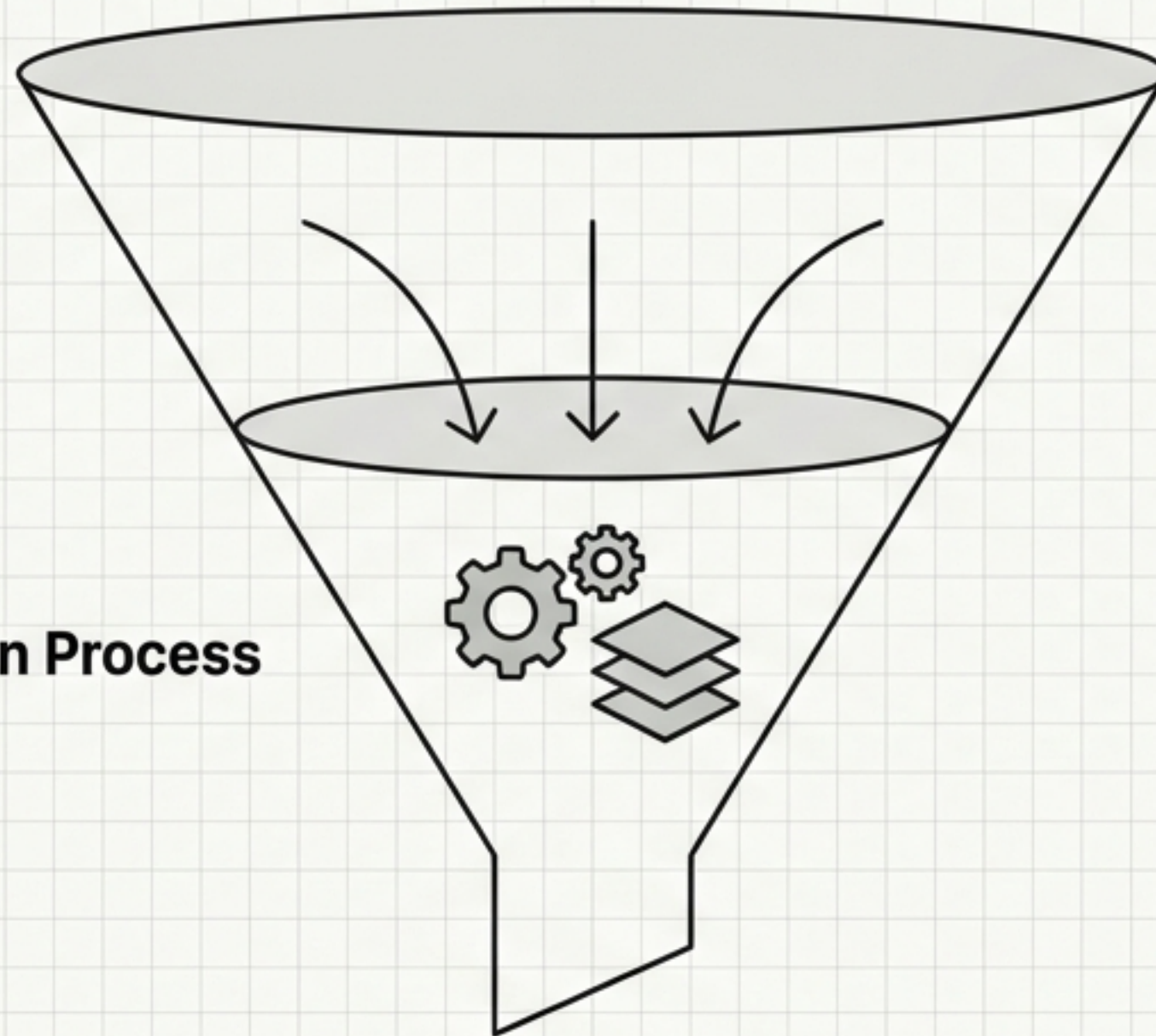
Within the day, we correlate for abuse detection. After the day, without the salt, the hash is mathematically impossible to reverse. This meets the ICO 'Effective Anonymisation' standard.

Mitigating the 'User-Agent' Fingerprint

Input (Toxic - ~10 bits entropy)

Mozilla/5.0 (Macintosh; Intel Mac
OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/110.0.0.0
Safari/537.36

Normalisation Process



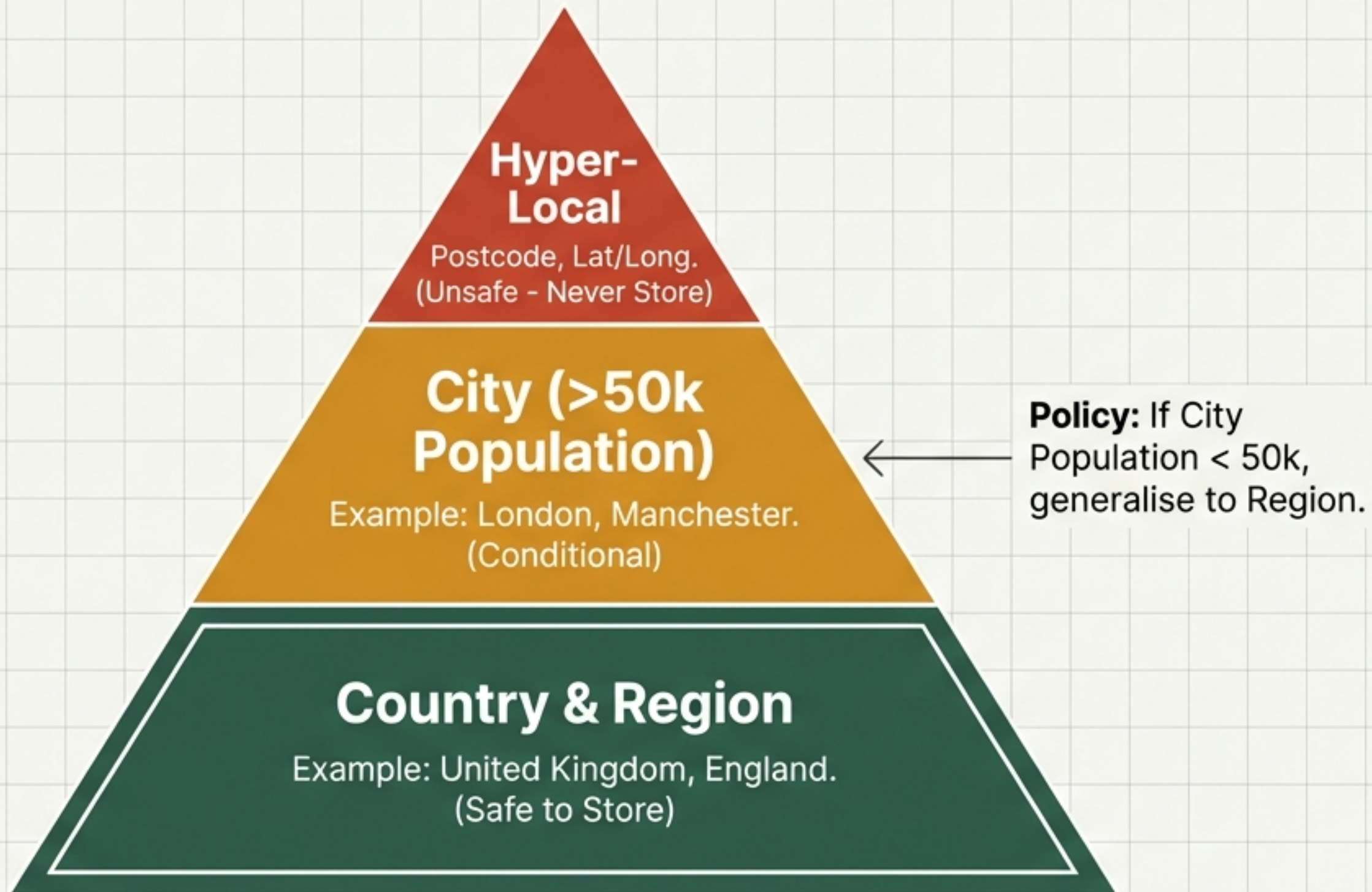
Output (Safe Category)

Chrome / macOS

Rule:

Store the category, discard the version numbers. Raw User-Agents combined with IP and Timezone create a unique identifier.

Geolocation Granularity & k-Anonymity

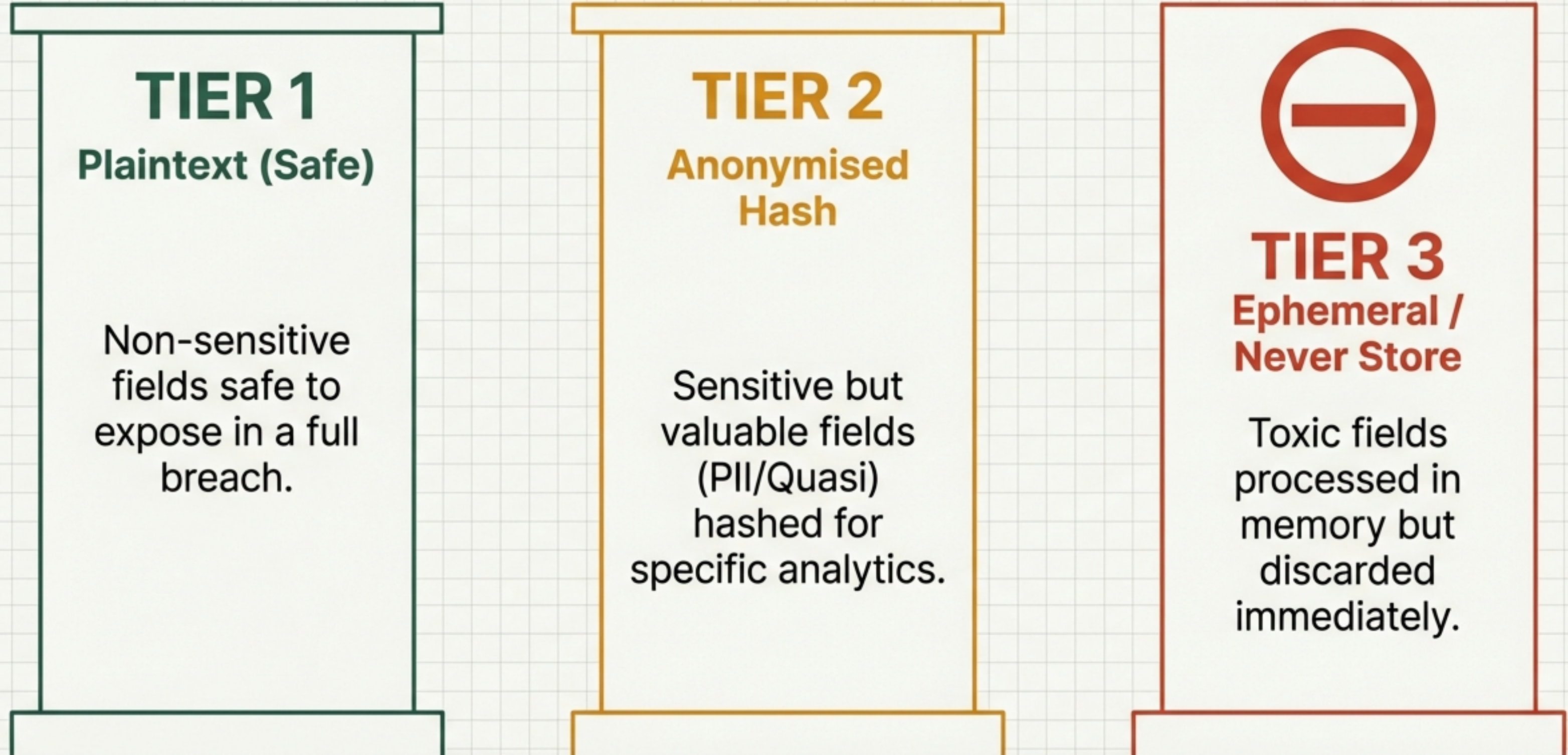


The Math: k-anonymity.

We aim for $k > 10,000$ (a stored value must apply to at least 10,000 people).

UK Postcodes (e.g., SW1A 1AA) identify ~15 households. Storing this is surveillance, not analytics.

The Three-Tier Storage Framework



Storage Schema: Tier 1 & Tier 2 Details

Tier 1: Plaintext (Safe)

Timestamp	→ Truncated to nearest hour (Removes timing attacks)
------------------	--

Country/Region	→ Broad geography
-----------------------	-------------------

Device Type	→ Mobile / Desktop
--------------------	--------------------

Flags	→ TLS Version, VPN Boolean
--------------	----------------------------

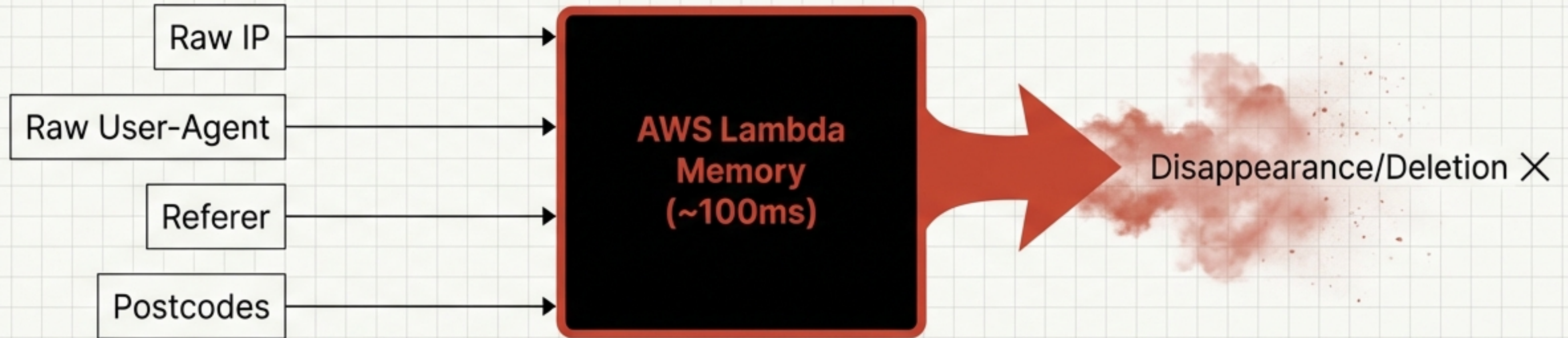
Tier 2: Anonymised Hash

IP Hash	→ HMAC(IP, daily_salt)
	Allows daily unique visitor counts.

ASN Hash	→ HMAC(ASN, daily_salt)
ASN Hash	→ HMAC(ASN, daily_salt)

Detects network-level abuse without identifying small corporate networks.

Tier 3: The Ephemeral Layer



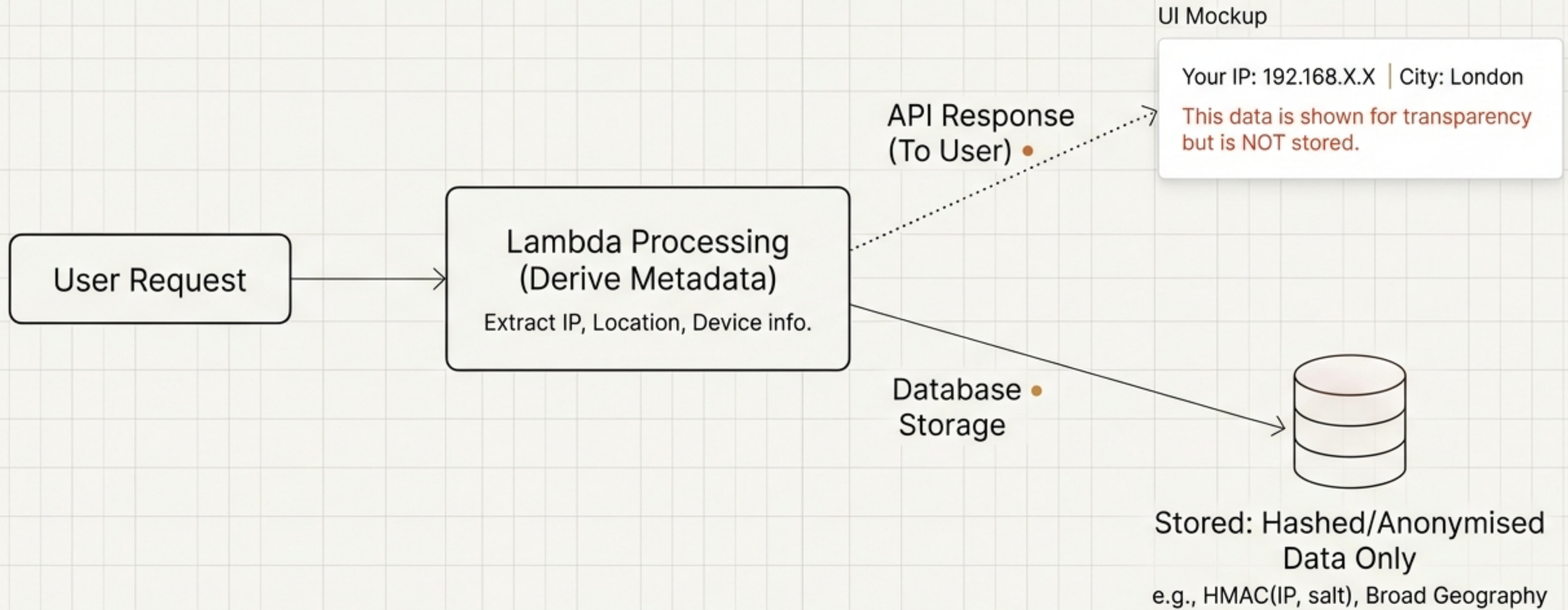
The Process: Data exists only in execution memory.

Legal Basis: Processing covered by Legitimate Interest (Art. 6(1)(f) GDPR) for security and service delivery.

Storage: None. Data is discarded before hitting S3/DynamoDB.

Note: Referer is logged only to CloudWatch if an error occurs (24h retention).

Transparency Strategy: Show Live, Store Anonymised



Analytics Trade-off Analysis

Retained Capabilities	Sacrificed Capabilities
✓ Downloads/Uploads per Country ✓ Device & Browser distribution (via normalised UA) ✓ Abuse detection (Same-IP correlation within 24h) ✓ VPN/Tor usage rates	✖ Cross-day user tracking (The hash changes daily) ✖ Sub-city geolocation (No street-level targeting) ✖ ISP-level targeting (ASNs are hashed)

Verdict: The privacy gain outweighs the analytic loss.

Implementation Checklist

1

Conduct DPIA (Art. 35 GDPR)

Document the salt destruction process and k-anonymity logic.

2

Update Privacy Notice

Cite Legitimate Interest and explain the “daily anonymity” model.

3

Engineering: Automate Salt Rotation

Configure AWS Secrets Manager to auto-delete keys at 00:00 UTC.

4

Engineering: Population Thresholding

Implement the 50,000 population check using GeoNames API.

5

Documentation: Salt Destruction

Record the destruction process—this is the primary legal defence.

Key Legal Basis & References

- Breyer v Bundesrepublik Deutschland (C-582/14) – Dynamic IPs as PII.
- EDPB Guidelines 01/2025 – Pseudonymisation vs. Anonymisation.
- ICO Guidance (March 2025) – The ‘Effective Anonymisation’ standard.
- EFF Panopticlick (Eckersley, 2010) – User-Agent entropy analysis.
- Dutch DPA Guidance – Risks of hashing without salt.

This framework aligns with the strictest interpretations of EU and UK privacy law as of 2025.